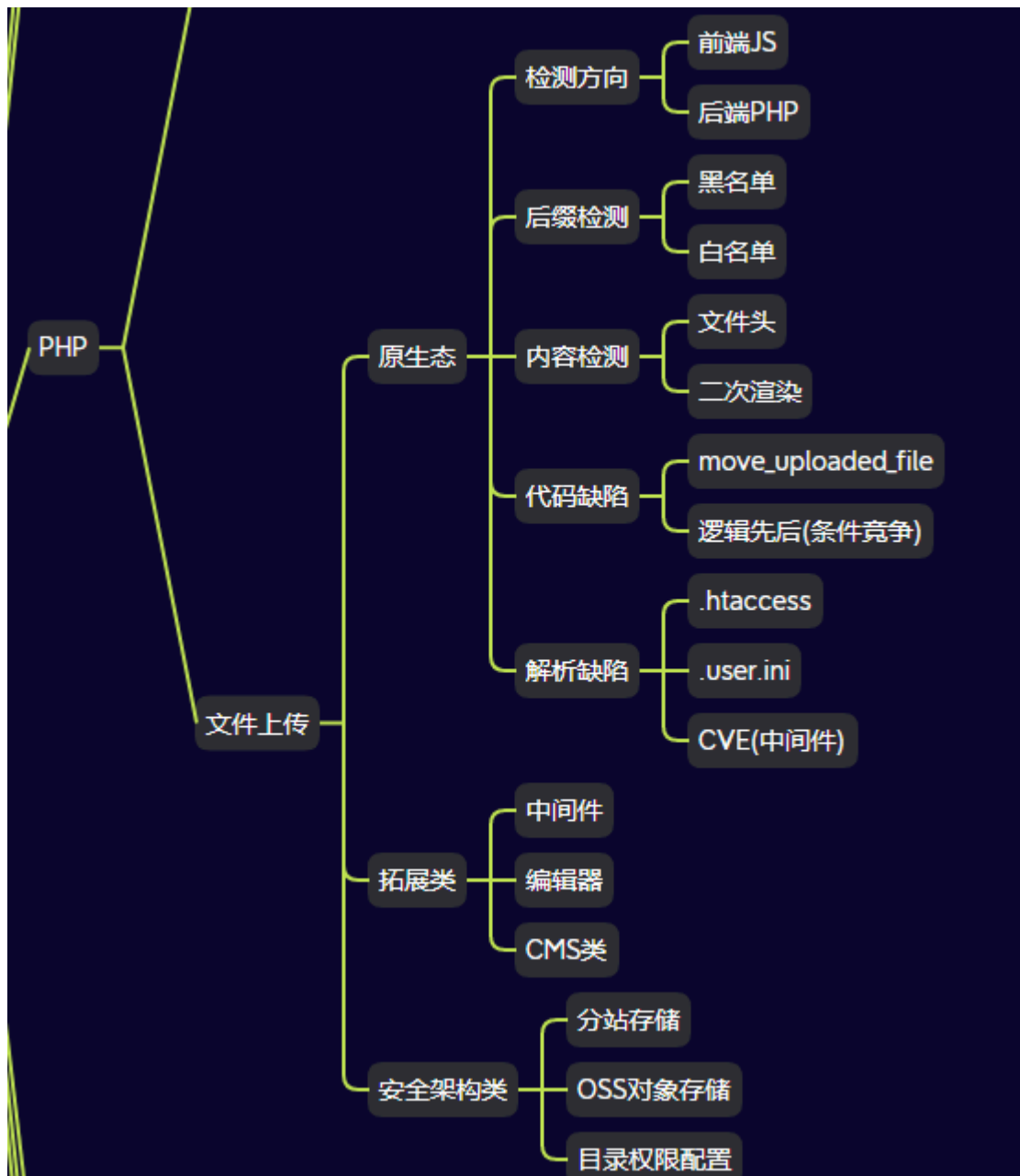


Day49 WEB攻防-文件上传&存储安全&OSS对象&分站&解析安全&解码还原&目录执行



1.知识点

- 1、ASP-SQL注入-Access数据库
- 2、ASP-默认安装-数据库漏洞下载
- 3、ASP-IIS-CVE&短文件&解析&写入

-
- 1、PHP-MYSQL-SQL注入-常规查询
 - 2、PHP-MYSQL-SQL注入-跨库查询

- 3、PHP-MYSQL-SQL注入-文件读写

-
- 1、PHP-MYSQL-SQL注入-数据请求类型
 - 2、PHP-MYSQL-SQL注入-数据请求方法
 - 3、PHP-MYSQL-SQL注入-数据请求格式

-
- 1、PHP-MYSQL-SQL注入-方式增删改查
 - 2、PHP-MYSQL-SQL注入-布尔&延迟&报错
 - 3、PHP-MYSQL-SQL注入-数据回显&报错处理

-
- 1、PHP-MYSQL-SQL注入-二次注入&利用条件
 - 2、PHP-MYSQL-SQL注入-堆叠注入&利用条件
 - 3、PHP-MYSQL-SQL注入-带外注入&利用条件

-
- 1、注入工具-SQLMAP-常规猜解&字典配置
 - 2、注入工具-SQLMAP-权限操作&文件命令
 - 3、注入工具-SQLMAP-Tamper&使用&开发
 - 4、注入工具-SQLMAP-调试指纹&风险等级

-
- 1、PHP-原生态-文件上传-检测后缀&黑白名单
 - 2、PHP-原生态-文件上传-检测信息&类型内容
 - 3、PHP-原生态-文件上传-函数缺陷&逻辑缺陷
 - 4、PHP-原生态-文件上传-版本缺陷&配置缺陷

-
- 1、PHP-中间件-文件上传-CVE&配置解析
 - 2、PHP-编辑器-文件上传-第三方引用安全
 - 3、PHP-CMS源码-文件上传-已知识别到利用

-
- 1、文件上传-安全解析方案-目录权限&解码还原
 - 2、文件上传-安全存储方案-分站存储&OSS对象
-

2.演示案例

2.1 文件-解析方案-执行权限&解码还原



- 1 1、执行权限
- 2 文件上传后存储目录不给执行权限
- 3 2、解码还原
- 4 数据做存储，解析固定（文件后缀名无关）
- 5 文件上传后利用编码传输解码还原

2.2 文件-存储方案-分站存储&OSS对象



- 1 1、分站存储
- 2 `upload.xiaodi8.com` 上传
- 3 `images.xiaodi8.com` 存储
- 4 2、OSS对象
- 5 Access控制-OSS对象存储-Bucket对象

2.3 实例-解析存储-传输&分站&OSS存储



- 1 #如何判断
- 2 实例分析判断
- 3
- 4 #安全绕过
- 5 以上方案除目录设置权限如能换目录解析绕过外，其他均无解